

**ESCOLA  
SUPERIOR  
DE TECNOLOGIA  
E GESTÃO**

**P.PORTO**

## **Gestão de Riscos: Introdução**

# Sumário

---

- Conceitos introdutórios
- Gestão de risco
- Normas internacionais de gestão de risco
- Sistema de Gestão de Segurança da Informação
- Extra: controlos para tratamento do risco

# Conceitos Introdutórios

---

- Definição de sistemas críticos
  - A falha de alguns sistemas não provoca dano grave a longo prazo
  - Noutros, a falha de alguns sistemas (ou algumas falhas) tem consequências severas em termos de danos físicos ou ameaças para a vida humana, e/ou origina perdas económicas significativas → **sistema crítico**
  - Sistemas críticos são sistemas técnicos ou sócio-técnicos dos quais pessoas e negócios dependem
  - Se os sistemas críticos falharem a entrega de um serviço, como esperado, então problemas graves e perdas significativas podem ocorrer

# Conceitos Introdutórios

---

- Características essenciais dos sistemas críticos
  - Seguro [ou segurança das operações] (inglês: safety)
    - O sistema não deve prejudicar as pessoas ou o meio ambiente
  - **Segurança da informação (inglês: security)**
    - O sistema deve ser capaz de se proteger a si próprio e seus dados contra uso malicioso
  - Fiabilidade (inglês: reliability)
    - O sistema deve operar sem falhas sérias ou graves
  - Disponibilidade (inglês: availability)
    - O sistema deve estar disponível para fornecer serviços quando solicitado

# Conceitos Introdutórios

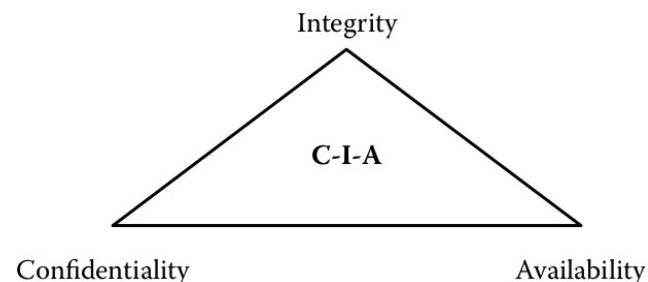
---

- Evolução dos bens/ativos das organizações
  - Bem/ativo – *“anything that has value to an organisation”*
    - Sujeitos a um amplo conjunto de ameaças
  - Bens/ativos tradicionais predominantemente tangíveis
    - Edifícios, secretárias, dinheiro e outros bens negociáveis (e.g., ouro)
    - Preocupações de segurança ao nível físico: guardas, cofres, paredes, ...
  - Bens/ativos atuais são virtuais (informação)
    - Propriedade intelectual (ficheiros Word, bases de dados, folhas de cálculo, ...)
    - Transações ao nível de bits, transferência de bits armazenados em discos
    - Informação é, em muitos casos, o bem/ativo mais precioso de uma organização

# Conceitos Introdutórios

---

- Visão tradicional de segurança da informação
  - Objetivos da segurança
    - Confidencialidade – assegurar que apenas entidades autorizadas têm acesso à informação
    - Integridade – proteger contra alterações não autorizadas, destruição da informação, ou que a informação permanece no formato intencionado
    - Disponibilidade – garantir que a informação está acessível para utilização
  - Três princípios sob ameaça permanente e em constante evolução
  - Medidas defensivas devem ser tomadas para mitigar o risco dentro da organização



# Gestão de Risco

---

- Questão

- Como pode uma organização gerir a segurança da informação e cumprir com os três objetivos da segurança?

- Resposta

- Implementar um Sistema de Gestão de Segurança da Informação (SGSI)
  - Um SGSI preserva a confidencialidade, integridade e disponibilidade da informação pela **aplicação de um processo de gestão de riscos** e fornece confiança às partes interessadas de que os riscos são adequadamente geridos

# Gestão de Risco

---

- Risco (definição segundo ISO/IEC Guide 73)
  - Combinação da probabilidade de um acontecimento e das suas consequências
  - Probabilidade de que uma ameaça irá ocorrer e a medida do efeito causado
  - A existência de atividade implica a possibilidade de ocorrência de eventos ou situações cujas consequências constituem ameaças (em alguns casos, constituem vantagens e oportunidades)

# Gestão de Risco

---

- Gestão de riscos
  - Processo através do qual uma organização analisa metodicamente os riscos inerentes às atividades, visando atingir uma vantagem sustentada
  - Elemento central na gestão da estratégia de qualquer organização
  - Aumenta a probabilidade de êxito e reduz a probabilidade de fracasso e incerteza na obtenção dos objetivos da organização
  - Ponto central consiste na identificação e tratamento de riscos

# Gestão de Risco

---

- Norma internacional ISO 31000
  - Estabelece como organizar a gestão de riscos em organizações (i.e., o que envolve a gestão de riscos, como deve ser implementada e o que ela pode alcançar)
  - Apresenta um glossário detalhado de termos relacionados com a gestão de riscos, explica os princípios básicos da gestão de riscos, e providencia uma estrutura geral, incluindo um ciclo PDCA (planeamento, implementação, monitorização e melhoria – Plan/Do/Check/Act)
  - Aplicável a qualquer tipo de organização e a qualquer tipo de risco, mas **não fornece uma metodologia específica para gestão de riscos de segurança informática**

# SGSI

---

- Sistema de Gestão de Segurança da Informação
  - Baseado em princípios da gestão de risco
  - Gestão de riscos cada vez mais importante na condução de negócios
  - Riscos podem afetar uma organização a curto, médio, longo prazo
  - É importante para as organizações reconhecer e priorizar os riscos significativos e identificar os controlos críticos mais fracos
    - Controlo é uma salvaguarda contra vulnerabilidades, reduzindo o potencial da ameaça (redução da probabilidade do risco) e do seu impacto na organização

Podem ser categorizados como sendo preventivos, de deteção ou corretivos

# SGSI

---

- Sistema de Gestão de Segurança da Informação
  - É uma abordagem de gestão estruturada e coerente à segurança da informação
    - Em termos de modelo de maturidade de capacidade, posicionar-se além de organização “*ad-hoc*” (sem processos/procedimentos fixos, resultados variados)
  - Inclui estrutura organizacional, políticas, atividades de planeamento, responsabilidades, práticas, procedimentos, processos e recursos, devidamente documentados
  - Projetado para assegurar efetiva interação dos três componentes chave da implementação de políticas de segurança informática
    - Processos (ou procedimentos)
    - Tecnologia
    - Comportamento dos utilizadores

# SGSI

---

- Sistema de Gestão de Segurança da Informação
  - Deve ser parte integrante dos processos da organização e da estrutura da administração
    - A segurança da informação deve ser considerada no projeto dos processos, sistemas de informação e controlos
  - Especificação e implementação do SGSI de uma organização são influenciadas por
    - Necessidades e objetivos
    - Requisitos de segurança
    - Processos organizacionais
    - Funcionários
  - Fatores influenciadores mudam ao longo do tempo

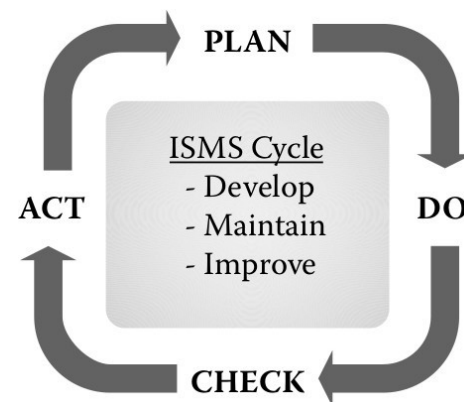
# SGSI

ISO 27000 define segurança da informação como "*preservation of confidentiality, integrity and availability of information; in addition, other properties such as authenticity, accountability, non-repudiation*"

- Como implementar?
  - Usar normas ISO/IEC como guia/diretrizes
    - International Standards Organization (ISO)
    - International Electrotechnical Commission (IEC)
    - Normas providenciam ferramentas de trabalho de melhores práticas reconhecidas globalmente
- Série/Família ISO/IEC 27000
  - Descreve a visão geral e o vocabulário do SGSI e referencia as normas da família (e.g., ISO/IEC 27003, ISO/IEC 27004 e ISO/IEC 27005), com termos e definições relacionados
  - Baseada em princípios de gestão de risco (ISO 31000), fornece uma metodologia específica para **gestão de riscos aplicados à segurança da informação**

# Série/Família ISO/IEC 27000

- Assenta em várias partes mais pequenas
  - Para ser facilmente gerível...
  - Cada parte prescreve um conjunto de atividades pertencentes a diferentes fases do ciclo PDCA
    - P – Plan
    - D – Do
    - C – Check
    - A – Act/Adjust
  - Define SGSI
    - *“part of the overall management system, based on a business risk approach, to establish, implement, operate, monitor, review, maintain and improve information security. The management system includes organisational structure, policies, planning activities, responsibilities, practices, procedures, processes and resources”*



# Série/Família ISO/IEC 27000

---

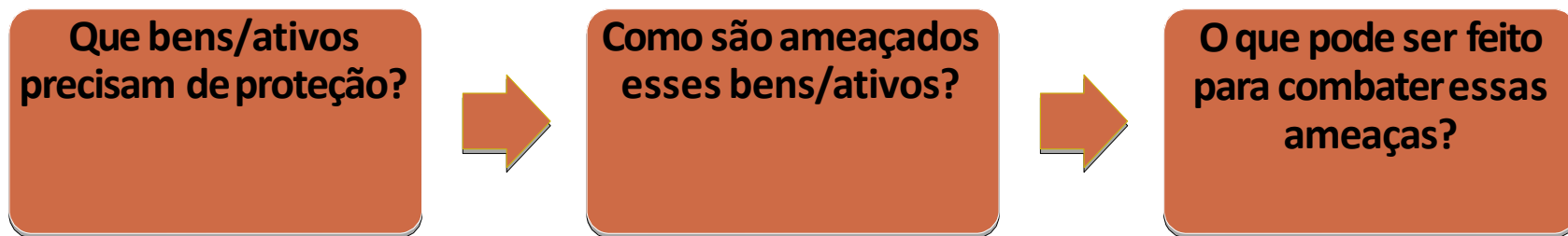
- Notas gerais

- Descreve como organização deve organizar a segurança da info.
  - Permite alcançar e manter níveis adequados de confidencialidade, integridade e disponibilidade (responsabilidade, autenticidade e confiabilidade)
- Baseada em princípios de gestão de risco (ISO31000)
  - Incluir determinar requisitos, objetivos, estratégias, políticas de segurança, identificar e analisar ameaças à segurança, especificar salvaguardas adequadas, para proteger de forma economicamente viável os bens/ativos
- A organização deve seleccionar salvaguardas (controles de segurança) apenas se existirem riscos inaceitáveis que precisem de ser tratados
- Pode ser implementada em qualquer tipo de organização
  - É a mais popular norma de segurança da informação no mundo

# Série/Família ISO/IEC 27000

- Notas gerais

- Processo formal de responder às seguintes questões



- Assegura que os bens críticos sejam suficientemente protegidos de forma economicamente viável
    - A avaliação do risco de segurança é necessária para cada bem da organização que requer proteção
    - Fornece as informações necessárias para decidir quais controlos administrativos, operacionais e técnicos são necessários para reduzir os riscos identificado

# Série/Família ISO/IEC 27000

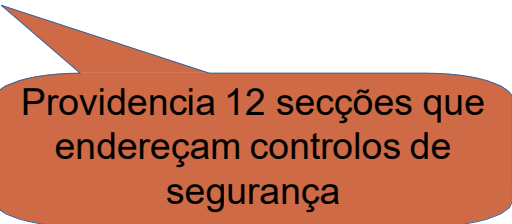
---

- Norma ISO 27001
  - Especifica os requisitos
    - Para estabelecer, implementar, manter e melhorar continuamente um SGSI dentro do contexto da organização
    - Para avaliação e tratamento de riscos de segurança da informação de acordo com as necessidades da organização
  - Requisitos definidos são genéricos
    - Aplicáveis a todas as organizações independentemente do tipo, tamanho ou natureza
  - Norma internacional auditável, avaliável, e certificável por entidade de certificação
    - Providencia confiança junto de clientes, parceiros, e partes interessadas
  - Similar à fase “Plan” do ciclo PDCA

# Série/Família ISO/IEC 27000

---

- Norma ISO 27002
  - Detalha controlos de segurança da informação
    - Não refere como aplicar os controlos – fica à responsabilidade da organização
  - Recomendável a sua utilização em conjunto com a ISO 27001
    - Guiado pelo resultado da avaliação de risco realizada pela ISO 27001
    - ISO 27001 estabelece boas práticas sobre aplicação dos controlos
  - Similar à fase “Do” do ciclo PDCA



Providencia 12 secções que endereçam controlos de segurança

# Série/Família ISO/IEC 27000

---

- Norma ISO 27003

- Recomendações e melhores práticas para implementação dos controlos associados ao SGSI definidos pelo ISO 27001
  - Ou seja, como entregar o programa de segurança
- Similar à fase “Check” do ciclo PDCA

- Norma ISO 27004

- Cobre medições da efetividade do SGSI implementado pelas três primeiras normas
  - Usa métricas KPIs (key performance indicators) para descrever quão bem os controlos operam
- Similar à fase “Act/Adjust” do ciclo PDCA

# Série/Família ISO/IEC 27000

---

- Relação entre normas ISO 27001 e ISO 27002
  - ISO 27001
    - Relacionado com “Como?” - procedimento sobre como instalar sistema de gestão que guia na implementação e manutenção dos controlos de segurança
    - Especifica os **requisitos** para estabelecer, implementar, operar, monitorizar, rever, manter, e aperfeiçoar um SGSI documentado
    - Apresenta processo de gestão visando consciência de segurança, instalação de infraestrutura organizacional, planear, implementar, e manter controlos de seg.
  - ISO 27002
    - Providencia diretrizes para gestão de segurança da informação na organização
    - Apresenta lista de melhores práticas para controlos de segurança
    - Seleção, implementação e gestão de controlos, considerando os **requisitos** (ambientes de risco encontrados na organização)
    - Relacionado com “Oquê?” - lista de controlos úteis

# Série/Família ISO/IEC 27000

---

- Relação entre normas ISO 27001 e ISO 27002
  - ISO 27001
    - É uma especificação para um SGSI
    - Usa palavras como “*shall*”
    - Define requisitos
    - Auditorias (próprias, parceiros e de terceiros) podem ser realizadas
    - Prescritiva (não dá espaço para escolha como no caso da ISO 27002)
  - ISO 27002
    - Código de boas práticas ou conjunto de diretrizes
    - Usa palavras como “*should*”, “*may*”
    - Permite às organizações escolher os elementos da norma a implementar
    - Não é auditável (porque organizações podem escolher elementos...)

# Série/Família ISO/IEC 27000

- Norma ISO 27002

- Políticas de segurança da informação
- Organização da segurança da informação
- Segurança ao nível dos recursos humanos
- Gestão de bens/ativos
- Controlo de acessos
- Criptografia
- Segurança física e domeio
- Segurança das operações
- Segurança das comunicações
- Aquisição, desenvolvimento e manutenção de sistemas de informação
- Gestão de incidentes em segurança da informação
- Relações com fornecedores
- Gestão de incidentes de segurança da informação
- Gestão da continuidade do negócio
- Conformidade

Providencia 12 secções que endereçam controlos de segurança

Anexo A da norma ISO 27001 são derivados e estão alinhados com aqueles listados

# Série/Família ISO/IEC 27000

---

- Controlos de segurança
  - São medidas para detetar, evitar e/ou mitigar os efeitos de falhas de segurança
  - Existem vários tipos de controlos
    - Gestão ou administrativos
    - Operacionais
    - Processos e procedimentos técnicos

EXTRA

# Controlos da norma ISO 27002

---

- Políticas de segurança da informação
  - Objetivo – orientação da administração para segurança da informação
    - Criar documento com política de segurança de acordo com os requisitos do negócio e com as leis e regulamentações relevantes
    - Documento deve conter declarações claras sobre comportamento esperado das partes de forma a proteger bens/ativos e conduzir ao sucesso do negócio
    - Política de segurança especifica o que deve ser feito, não como (não especifica tecnologias)
  - Controlos
    - Políticas de segurança – definido conjunto de políticas de segurança, aprovado pela gestão, publicado e comunicado às partes (funcionários, partes externas relevantes, ...)
    - Revisão das políticas de segurança – políticas analisadas criticamente em intervalos de tempo planeados ou quando ocorrem mudanças significativas

# Controlos da norma ISO 27002

---

- Controlos (cont.)
  - Segurança da informação na gestão de projetos – considerar a segurança da informação na gestão de projetos, independentemente do tipo do projeto
- Organização da segurança da informação
  - Objetivo – dispositivos móveis e trabalho remoto
    - Garantir a segurança das informações no trabalho remoto e na utilização de dispositivos móveis
  - Controlos
    - Política para o uso de dispositivo móvel – adotar uma política e medidas que apoiam a segurança da informação para gerir os riscos decorrentes do uso de dispositivos móveis
    - Trabalho remoto – implementar uma política e medidas que apoiam a segurança da Informação para proteger as informações acedidas, processadas ou armazenadas em locais de trabalho remoto

# Controlos da norma ISO 27002

---

- Organização da segurança da informação
  - Objetivo – organização interna
    - Estabelecer uma estrutura de gestão para iniciar e controlar a implementação e operação da segurança da informação dentro da organização
  - Controlos
    - Responsabilidades e papéis pela segurança da informação – definir e atribuir responsabilidades pela segurança da informação
    - Segregação de funções – segregar funções conflitantes e áreas de responsabilidade para reduzir as oportunidades de modificação não autorizada ou não intencional, ou uso indevido dos bens/ativos da organização
    - Contacto com autoridades – manter contactos apropriados com autoridades relevantes
    - Contacto com grupos especiais – manter contactos apropriados com grupos especiais, associações profissionais ou outros fóruns especializados em segurança da informação

# Controlos da norma ISO 27002

---

- Segurança ao nível dos recursos humanos
  - Objetivo – antes da contratação
    - Assegurar que funcionários e partes externas entendem suas responsabilidades e estão em conformidade com os papéis para os quais foram selecionados
  - Controlos
    - Seleção – realizar verificações do histórico para todos os candidatos a emprego, de acordo com a ética, regulamentações e leis relevantes, devendo ser proporcional aos requisitos do negócio, aos riscos percebidos e à classificação das informações a serem acedidas
    - Termos e condições de contratação - as obrigações contratuais com funcionários e partes externas devem declarar as suas responsabilidades e a da organização para a segurança da informação

# Controlos da norma ISO 27002

---

- Segurança ao nível dos recursos humanos
  - Objetivo – durante a vigência do contrato
    - Assegurar que os funcionários e partes externas estão conscientes e cumpridores das suas responsabilidades para com segurança da informação
  - Controlos
    - Responsabilidades da administração – administração deve requerer aos funcionários e partes externas que pratiquem a segurança da informação de acordo com o estabelecido nas políticas e procedimentos da organização
    - Consciencialização, educação e treino em segurança da informação - todos os funcionários da organização e, onde pertinente, partes externas devem receber treino, educação e consciencialização apropriados, e as atualizações regulares das políticas e procedimentos organizacionais relevantes para as suas funções
    - Processo disciplinar - deve existir um processo disciplinar formal, implementado e comunicado, para tomar ações contra funcionários que tenham cometido uma violação de segurança da informação

# Controlos da norma ISO 27002

---

- Segurança ao nível dos recursos humanos
  - Objetivo – término do contrato
    - Proteger os interesses da organização como parte do processo de mudança ou término da contratação
  - Controlos
    - Responsabilidades pelo término ou mudança da contratação – as responsabilidades e obrigações pela segurança da informação que permaneçam válidas após o término ou mudança da contratação devem ser definidas, comunicadas aos funcionários ou partes externas e cumpridas

# Controlos da norma ISO 27002

---

- Gestão de bens/ativos
  - Objetivos – responsabilidade pelos bens/ativos
    - Identificar os bens/ativos da organização e definir as devidas responsabilidades pela sua proteção
  - Controlos
    - Inventariação dos bens/ativos – identificar os ativos associados com informação e com os recursos de processamento da informação, e estruturar e manter um inventário destes ativos
    - Proprietário dos ativos – associar a um proprietário os ativos mantidos no inventário
    - Uso aceitável dos ativos - regras para o uso aceitável das informações, dos ativos associados com informação e os recursos de processamento da informação, devem ser identificados, documentados e implementados
    - Devolução de ativos - funcionários e partes externas devem devolver os ativos da organização que estejam em sua posse após término das suas atividades (tipicamente relacionado com níveis de acesso privilegiado – administradores de sistemas, etc.)

# Controlos da norma ISO 27002

---

- Gestão de bens/ativos
  - Objetivo – classificação da informação
    - Assegurar que a informação recebe um nível adequado de proteção, de acordo com a sua importância para a organização
  - Controlos
    - Classificação da informação – classificar a informação em termos do seu valor, requisitos legais, sensibilidade e criticidade para evitar modificação ou divulgação não autorizada
    - Rótulos e tratamento da informação – desenvolver e implementar um conjunto apropriado de procedimentos para rotular e tratar a informação de acordo com o esquema de classificação da informação adotado pela organização
    - Tratamento dos ativos – desenvolver e implementar procedimentos para o tratamento dos ativos de acordo com o esquema de classificação da informação adotada pela organização

# Controlos da norma ISO 27002

---

- Gestão de bens/ativos
  - Objetivo – tratamento de dispositivos média
    - Prevenir a divulgação não autorizada, modificação, remoção ou destruição da informação armazenada em dispositivos média
  - Controlos
    - Gestão de dispositivos removíveis – devem ser implementados procedimentos para gestão de dispositivos removíveis, de acordo com o esquema de classificação adotado pela organização
    - Descarte de dispositivos – os dispositivos devem ser descartadas de forma segura e protegida quando não forem mais necessárias, por meio de procedimentos formais
    - Transferência física de dispositivos – dispositivos contendo informações devem ser protegidos contra acesso não autorizado, uso impróprio ou corrompido, durante o transporte

# Controlos da norma ISO 27002

---

- Controlo de acessos
  - Objetivos - requisitos do negócio para controlo de acesso
    - Limitar o acesso à informação e aos recursos de processamento da informação
  - Controlos
    - Política de controlo de acesso – deve ser estabelecida uma política de controlo de acesso, documentada e analisada criticamente, baseada nos requisitos de segurança da informação e dos negócios
    - Acesso às redes e aos serviços da rede - os utilizadores devem somente receber acesso às redes e aos serviços de rede que tenham sido especificamente autorizados a usar

# Controlos da norma ISO 27002

---

- Controlo de acessos
  - Objetivos – gestão de acesso do utilizador
    - Assegurar acesso a utilizador autorizado e prevenir acesso não autorizado a sistemas e serviços
  - Controlos
    - Registo e cancelamento de utilizador – deve ser implementado um processo formal de registo e cancelamento de utilizador para permitir atribuição de direitos de acesso
    - Atribuição de acesso a utilizador - deve ser implementado um processo formal de fornecimento de acesso a utilizador para conceder ou revogar os direitos de acesso do utilizador para todos os tipos de utilizador em todos os tipos de sistemas e serviços
    - Gestão de direitos de acesso privilegiados – deve ser restrita e controlada a concessão e uso de direitos e acesso privilegiado

# Controlos da norma ISO 27002

---

- Controlo de acessos
  - Objetivos – gestão de acesso do utilizador
    - Assegurar acesso a utilizador autorizado e prevenir acesso não autorizado a sistemas e serviços
  - Controlos
    - Gestão da informação de autenticação secreta de utilizadores – a concessão de informação de autenticação secreta deve ser controlada por meio de um processo de gestão formal
    - Revisão dos direitos de acesso de utilizador - os proprietários de bens/ativos devem rever os direitos de acesso dos utilizadores, em intervalos regulares
    - Remoção ou ajuste de direitos de acesso - os direitos de acesso de todos os funcionários e partes externas às informações e aos recursos de processamento da informação devem ser removidos após o término de suas atividades, contratos ou acordos, ou ajustados após a mudança destas atividades

# Controlos da norma ISO 27002

---

- Controlo de acessos
  - Objetivos – responsabilidades dos utilizadores
    - Tornar os utilizadores responsáveis pela proteção das suas informações de autenticação
  - Controlos
    - Uso da informação de autenticação secreta - os utilizadores devem ser orientados a seguir as práticas da organização quanto ao uso da informação de autenticação secreta

# Controlos da norma ISO 27002

---

- Controlo de acessos

- Objetivos – controlo de acesso ao sistema e à aplicação
  - Prevenir o acesso não autorizado aos sistemas e aplicações
- Controlos
  - Restrição de acesso à informação - o acesso à informação e as funções dos sistemas de aplicações devem ser restrito de acordo com a política de controlo de acesso
  - Procedimentos seguros de entrada no sistema (*logon*) - onde aplicável pela política de controlo de acesso, o acesso aos sistemas e aplicações deve ser controlado por um procedimento seguro de entrada no sistema (*logon*)
  - Sistema de gestão de senhas - sistemas de gestão de senhas devem ser interativos e devem assegurar senhas de qualidade
  - Uso de programas utilitários privilegiados - o uso de programas utilitários que podem ser capazes de sobrepor os controlos dos sistemas e aplicações deve ser restrito e estritamente controlado

# Controlos da norma ISO 27002

---

- Controlo de acessos
  - Objetivos – controlo de acesso ao sistema e à aplicação
    - Prevenir o acesso não autorizado aos sistemas e aplicações
  - Controlos
    - Controlo de acesso ao código-fonte de programas - o acesso ao código-fonte de programa deve ser restrito

# Controlos da norma ISO 27002

---

- Criptografia
  - Objetivo – controlos criptográficos
    - Assegurar o uso efetivo e adequado da criptografia para proteger a confidencialidade, autenticidade e/ou a integridade da informação
  - Controlos
    - Política para o uso de controlos criptográficos - deve ser desenvolvida e implementada uma política para o uso de controlos criptográficos para a proteção da informação
    - Gestão de chaves - uma política sobre o uso, proteção e ciclo de vida das chaves criptográficas, deve ser desenvolvida e implementada ao longo de todo o seu ciclo de vida

# Controlos da norma ISO 27002

---

- Segurança física e domeio
  - Objetivo – áreas seguras
    - Prevenir o acesso físico não autorizado, danos e interferências com os recursos de processamento de informação e informações da organização
  - Controlos
    - Perímetro de segurança física - perímetros de segurança devem ser definidos e usados para proteger tanto as áreas que contenham as instalações de processamento da informação como as informações críticas ou sensíveis
    - Controlos de entrada física - as áreas seguras devem ser protegidas por controlos apropriados de entrada para assegurar que somente pessoas autorizadas tenham acesso permitido
    - Segurança em escritórios, salas e instalações - deve ser projetada e aplicada segurança física para escritórios, salas e instalações
    - Proteção contra ameaças externas e do meio - deve ser projetada e aplicada proteção física contra desastres naturais, ataques maliciosos ou acidentes

# Controlos da norma ISO 27002

---

- Segurança física e domeio
  - Objetivo – áreas seguras
    - Prevenir o acesso físico não autorizado, danos e interferências com os recursos de processamento de informação e informações da organização
  - Controlos
    - Trabalho em áreas seguras - devem ser projetados e aplicados procedimentos para o trabalho em áreas seguras
    - Áreas de entrega e de carregamento - pontos de acesso, tais como áreas de entrega e de carregamento e outros pontos em que pessoas não autorizadas possam entrar nas instalações, devem ser controlados e, se possível, isolados das instalações de processamento da informação, para evitar o acesso não autorizado

# Controlos da norma ISO 27002

---

- Segurança física e domeio
  - Objetivo – equipamentos
    - Impedir perdas, danos, furto ou roubo, ou comprometimento de ativos e interrupção das operações da organização
  - Controlos
    - Escolha de local e proteção do equipamento - os equipamentos devem ser colocados no local ou protegidos para reduzir os riscos de ameaças e perigos do meio, bem como as oportunidades de acesso não autorizado
    - Utilitários de apoio - os equipamentos devem ser protegidos contra falta de energia elétrica e outras interrupções causadas por falhas das utilidades
    - Segurança da cablagem – a cablagem de energia e de telecomunicações que transporta dados ou dá suporte aos serviços de informação deve ser protegida contra interceção, interferência ou danos
    - Manutenção dos equipamentos - os equipamentos devem ter uma manutenção correta para assegurar sua disponibilidade e integridade permanente

# Controlos da norma ISO 27002

---

- Segurança física e domeio
  - Objetivo – equipamentos
    - Impedir perdas, danos, furto ou roubo, ou comprometimento de ativos e interrupção das operações da organização
  - Controlos
    - Remoção de ativos - equipamentos, informações ou software não devem ser retirados do local sem autorização prévia
    - Segurança de equipamentos e bens/ativos fora das instalações da organização - devem ser tomadas medidas de segurança para bens/ativos que operem fora do local, levando em conta os diferentes riscos decorrentes do facto de se trabalhar fora das instalações da organização
    - Reutilização e alienação seguras de equipamentos - todos os equipamentos que contenham dispositivos removíveis de armazenamento de dados devem ser examinados antes do descarte, para assegurar que todos os dados sensíveis e software licenciado tenham sido removidos ou *sobre-gravados* em segurança

# Controlos da norma ISO 27002

---

- Segurança física e domeio
  - Objetivo – equipamentos
    - Impedir perdas, danos, furto ou roubo, ou comprometimento de ativos e interrupção das operações da organização
  - Controlos
    - Equipamento de utilizador desacompanhado - os utilizadores devem assegurar que os equipamentos não acompanhados têm proteção adequada
    - Política de mesa e ecrã limpos - deve ser adotada uma política de mesa limpa de papéis e dispositivos de armazenamento removíveis e uma política de ecrã limpo dos recursos de processamento da informação

# Controlos da norma ISO 27002

---

- Segurança das operações
  - Objetivo – responsabilidades e procedimentos operacionais
    - Garantir a operação segura e correta dos recursos de processamento da informação
  - Controlos
    - Documentação dos procedimentos operacionais - os procedimentos de operações devem ser documentados e disponibilizados a todos os utilizadores que deles necessitam
    - Gestão de alterações - mudanças na organização, nos processos de negócio, nos recursos de processamento da informação e nos sistemas que afetam a segurança da informação, devem ser controladas
    - Gestão da capacidade - a utilização dos recursos deve ser monitorizada, ajustada e as projeções devem ser feitas para necessidades de capacidade futura para garantir o desempenho requerido do sistema

# Controlos da norma ISO 27002

---

- Segurança das operações
  - Objetivo – responsabilidades e procedimentos operacionais
    - Garantir a operação segura e correta dos recursos de processamento da informação
  - Controlos
    - Separação dos ambientes de desenvolvimento, teste e de produção - ambientes de desenvolvimento, teste e produção devem ser separados para reduzir os riscos de acessos ou modificações não autorizadas no ambiente de produção

# Controlos da norma ISO 27002

---

- Segurança das operações
  - Objetivo – proteção contra malware
    - Assegurar que as informações e os recursos de processamento da informação estão protegidos contra malware
  - Controlos
    - Controlos contra malware - devem ser implementados controlos de deteção, prevenção e recuperação para proteger contra malware, combinado com um adequado programa de consciencialização do utilizador
  - Objetivo – cópias de segurança
    - Proteger contra a perda de dados
  - Controlos
    - Cópias de segurança das informações – cópias de segurança das informações, software e das imagens do sistema, devem ser efetuadas e testadas regularmente conforme a política de criação de cópias de segurança definida

# Controlos da norma ISO 27002

---

- Segurança das operações
  - Objetivo – registo e monitorização
    - Registrar eventos e gerar evidências
  - Controlos
    - Registo de eventos – registo de eventos (log) das atividades do utilizador, exceções, falhas e eventos de segurança da informação devem ser produzidos, mantidos e analisados criticamente, em intervalos regulares
    - Proteção das informações dos registos de eventos (logs) - as informações dos registos de eventos (log) e seus recursos devem ser protegidas contra acesso não autorizado e adulteração
    - Registo de eventos (log) de Administrador e Operador – as atividades dos administradores e operadores do sistema devem ser registadas e os registos (logs) devem ser protegidos e analisados criticamente, em intervalos regulares

# Controlos da norma ISO 27002

---

- Segurança das operações
  - Objetivo – registo e monitorização
    - Registar eventos e gerar evidências
  - Controlos
    - Sincronização dos relógios - os relógios de todos os sistemas de processamento de informações relevantes, dentro da organização ou do domínio de segurança, devem ser sincronizados com uma fonte de tempo precisa

# Controlos da norma ISO 27002

---

- Segurança das operações
  - Objetivo – controle de software operacional
    - Assegurar a integridade do software nos sistemas operativos
  - Controlos
    - Instalação de software nos sistemas operativos - devem ser implementados procedimentos para controlar a instalação de software em sistemas operativos

# Controlos da norma ISO 27002

---

- Segurança das operações
  - Objetivo – gestão de vulnerabilidades técnicas
    - Prevenir a exploração de vulnerabilidades técnicas
  - Controlos
    - Gestão de vulnerabilidades técnicas - informações sobre vulnerabilidades técnicas dos sistemas de informação em uso devem ser obtidas em tempo útil, com avaliação da exposição da organização a estas vulnerabilidades e tomadas as medidas apropriadas para lidar com os riscos associados
    - Restrições quanto à instalação de software - devem ser estabelecidas e implementadas regras definindo critérios para a instalação de software pelos utilizadores

# Controlos da norma ISO 27002

---

- Segurança das operações
  - Objetivo – considerações quanto à auditoria de sistemas de informação
    - Minimizar o impacto das atividades de auditoria nos sistemas operativos
  - Controlos
    - Controlos de auditoria de sistemas de informação – as atividades e requisitos de auditoria envolvendo a verificação nos sistemas operativos devem ser cuidadosamente planeados e acordados para minimizar interrupções nos processos do negócio

# Controlos da norma ISO 27002

---

- Segurança das comunicações
  - Objetivos – gestão da segurança em redes
    - Assegurar a proteção das informações em redes e dos recursos de processamento da informação que os apoiam
  - Controlos
    - Controlos de redes - as redes devem ser geridas e controladas para proteger as informações nos sistemas e aplicações
    - Segurança dos serviços da rede – mecanismos de segurança, níveis de serviço e requisitos de gestão de todos os serviços de rede, devem ser identificados e incluídos em qualquer acordo de serviços de rede, tanto para serviços de rede disponibilizados internamente como para terceiros
    - Segregação de redes - grupos de serviços de informação, utilizadores e sistemas de informação devem ser segregados em redes

# Controlos da norma ISO 27002

---

- Segurança das comunicações
  - Objetivos – transferência de informação
    - Manter a segurança da informação transferida dentro da organização e com quaisquer entidades externas
  - Controlos
    - Políticas e procedimentos para transferência de informações - políticas, procedimentos e controlos de transferências formais, devem ser estabelecidos para proteger a transferência de informações através do uso de todos os tipos de recursos de comunicação
    - Acordo para transferência de informações – devem ser estabelecidos acordos para transferência segura de informações de negócio entre a organização e partes externas
    - Mensagens eletrónicas - as informações que transitem em mensagens eletrónicas devem ser adequadamente protegidas

# Controlos da norma ISO 27002

---

- Segurança das comunicações
  - Objetivos – transferência de informação
    - Manter a segurança da informação transferida dentro da organização e com quaisquer entidades externas
  - Controlos
    - Acordos de confidencialidade e não divulgação - os requisitos para confidencialidade ou acordos de não divulgação que reflitam as necessidades da organização para a proteção da informação devem ser identificados, revistos e documentados

# Controlos da norma ISO 27002

---

- Aquisição, desenvolvimento e manutenção de sistemas de informação
  - Objetivo – requisitos de segurança de sistemas de informação
    - Garantir que a segurança da informação é parte integrante de todo o ciclo de vida dos sistemas de informação → inclui os requisitos para os sistemas de informação que fornecem serviços sobre as redes públicas
  - Controlos
    - Análise e especificação dos requisitos de segurança da informação – os requisitos relacionados com segurança da informação devem ser incluídos nos requisitos para novos sistemas de informação ou melhorias dos sistemas de informação existentes
    - Serviços de aplicação seguros sobre redes públicas – as informações envolvidas nos serviços de aplicação que transitam sobre redes públicas devem ser protegidas de atividades fraudulentas, disputas contratuais e divulgação e modificações não autorizadas

# Controlos da norma ISO 27002

---

- Aquisição, desenvolvimento e manutenção de sistemas de informação
  - Objetivo – requisitos de segurança de sistemas de informação
    - Garantir que a segurança da informação é parte integrante de todo o ciclo de vida dos sistemas de informação → inclui os requisitos para os sistemas de informação que fornecem serviços sobre as redes públicas
  - Controlos
    - Proteção de transações nas aplicações de serviços – informações envolvidas em transações nas aplicações de serviços devem ser protegidas para prevenir transmissões incompletas, erros de encaminhamento, alterações não autorizadas das mensagens, divulgação não autorizada, ou duplicação

# Controlos da norma ISO 27002

---

- Aquisição, desenvolvimento e manutenção de sistemas de informação
  - Objetivo – segurança em processos de desenvolvimento e de suporte
    - Garantir que a segurança da informação é projetada e implementada no ciclo de vida de desenvolvimento dos sistemas de informação
  - Controlos
    - Política de desenvolvimento seguro – regras para o desenvolvimento de sistemas e software devem ser estabelecidas e aplicadas aos desenvolvimentos realizados dentro da organização
    - Procedimentos para controlo de alterações de sistemas - alterações em sistemas dentro do ciclo de vida de desenvolvimento devem ser controladas utilizando procedimentos formais de controlo de alterações

# Controlos da norma ISO 27002

---

- Aquisição, desenvolvimento e manutenção de sistemas de informação
  - Objetivo – segurança em processos de desenvolvimento e de suporte
    - Garantir que a segurança da informação é projetada e implementada no ciclo de vida de desenvolvimento dos sistemas de informação
  - Controlos
    - Revisão técnica das aplicações após alterações nas plataformas operacionais - aplicações críticas de negócios devem ser analisadas criticamente e testadas quando plataformas operacionais são alteradas, para garantir que não haverá nenhum impacto adverso na operação da organização ou na segurança
    - Restrições sobre alterações em pacotes de software - alterações em pacotes de software devem ser desencorajadas e devem estar limitadas às mudanças necessárias, e todas as alterações devem ser estritamente controladas

# Controlos da norma ISO 27002

---

- Aquisição, desenvolvimento e manutenção de sistemas de informação
  - Objetivo – segurança em processos de desenvolvimento e de suporte
    - Garantir que a segurança da informação é projetada e implementada no ciclo de vida de desenvolvimento dos sistemas de informação
  - Controlos
    - Princípios para projetar sistemas seguros – princípios para projetar sistemas seguros devem ser estabelecidos, documentados, mantidos e aplicados para qualquer implementação de sistemas de informação
    - Ambiente de desenvolvimento seguro – as organizações devem estabelecer e proteger adequadamente os ambientes seguros de desenvolvimento, para os esforços de integração e desenvolvimento de sistemas, que cubram todo o ciclo de vida de desenvolvimento desistema

# Controlos da norma ISO 27002

---

- Aquisição, desenvolvimento e manutenção de sistemas de informação
  - Objetivo – segurança em processos de desenvolvimento e de suporte
    - Garantir que a segurança da informação é projetada e implementada no ciclo de vida de desenvolvimento dos sistemas de informação
  - Controlos
    - Desenvolvimento em *outsourcing* – a organização deve supervisionar e monitorizar as atividades de desenvolvimento de sistemas em *outsourcing*
    - Teste de segurança do sistema – testes de funcionalidade de segurança devem ser realizados durante o desenvolvimento de sistemas
    - Teste de aceitação de sistemas – programas de testes de aceitação e critérios relacionados devem ser estabelecidos para novos sistemas de informação, atualizações e novas versões

# Controlos da norma ISO 27002

---

- Aquisição, desenvolvimento e manutenção de sistemas de informação
  - Objetivo – dados para teste
    - Assegurar a proteção dos dados usados em testes
  - Controlos
    - Proteção dos dados para teste - os dados de teste devem ser selecionados com cuidado, protegidos e controlados

# Controlos da norma ISO 27002

---

- Relações com fornecedores
  - Objetivos – segurança da informação nas relações com fornec.
    - Garantir a proteção dos bens/ativos da organização que são acessíveis aos fornecedores
  - Controlo
    - Política de segurança da informação nas relações com fornecedores - requisitos de segurança da informação para mitigar os riscos associados com o acesso dos fornecedores aos bens/ativos da organização devem ser acordados com o fornecedor e documentados
    - Abordando segurança da informação nos contratos com fornecedores – todos os requisitos de segurança da informação relevantes devem ser estabelecidos e acordados com cada fornecedor que possa aceder, processar, armazenar, comunicar, ou disponibilizar componentes de infraestrutura de TI para as informações da organização

# Controlos da norma ISO 27002

---

- Relações com fornecedores
  - Objetivos – segurança da informação nas relações com fornec.
    - Garantir a proteção dos bens/ativos da organização que são acessíveis aos fornecedores
  - Controlo
    - Cadeia de fornecimento de tecnologia da informação e comunicação – acordos com fornecedores devem incluir requisitos para contemplar os riscos de segurança da informação associados com a cadeia de fornecimento de produtos e serviços de tecnologia das comunicações e informação

# Controlos da norma ISO 27002

---

- Relações com fornecedores
  - Objetivos – gestão da entrega de serviços do fornecedores
    - Manter um nível acordado de segurança da informação e de entrega de serviços em consonância com os acordos com fornecedores
  - Controlo
    - Monitorização e análise crítica de serviços com fornecedores – a organização deve monitorizar, rever e auditar em intervalos regulares, a entrega dos serviços executados pelos fornecedores
    - Gestão de alterações para serviços com fornecedores – alterações no fornecimento dos serviços pelos fornecedores, incluindo manutenção e melhoria das políticas de segurança da informação, dos procedimentos e controlos existentes, devem ser geridos, tendo em conta a criticidade das informações do negócio, dos sistemas e processos envolvidos, e a reavaliação de riscos

# Controlos da norma ISO 27002

---

- Gestão de incidentes em segurança da inform.
  - Objetivo – gestão de incidentes de segurança da inf. e melhorias
    - Assegurar uma consistente e efetiva abordagem à gestão de incidentes de segurança da informação, incluindo a comunicação sobre fragilidades e eventos de segurança da informação
  - Controlos
    - Responsabilidades e procedimentos – responsabilidades e procedimentos de gestão devem ser estabelecidos para assegurar respostas rápidas, efetivas e ordenadas a incidentes de segurança da informação
    - Notificação de eventos de segurança da informação – os eventos de segurança da informação devem ser relatados através dos canais apropriados da administração, o mais rapidamente possível

# Controlos da norma ISO 27002

---

- Gestão de incidentes em segurança da inform.
  - Objetivo – gestão de incidentes de segurança da inf. e melhorias
    - Assegurar uma consistente e efetiva abordagem à gestão de incidentes de segurança da informação, incluindo a comunicação sobre fragilidades e eventos de segurança da informação
  - Controlos
    - Notificação de fragilidades de segurança da informação – os funcionários e partes externas que usam os sistemas e serviços de informação da organização, devem ser instruídos a registar e notificar quaisquer fragilidades de segurança da informação, suspeita ou observada, nos sistemas ou serviços
    - Avaliação e decisão dos eventos de segurança da informação – os eventos de segurança da informação devem ser avaliados e deve ser decidido se eles são classificados como incidentes de segurança da informação
    - Resposta aos incidentes de segurança da informação – incidentes de segurança da informação devem ser reportados de acordo com procedimentos documentados

# Controlos da norma ISO 27002

---

- Gestão de incidentes em segurança da inform.
  - Objetivo – gestão de incidentes de segurança da inf. e melhorias
    - Assegurar uma consistente e efetiva abordagem à gestão de incidentes de segurança da informação, incluindo a comunicação sobre fragilidades e eventos de segurança da informação
  - Controlos
    - Aprender com os incidentes de segurança da informação – os conhecimentos obtidos da análise e resolução dos incidentes de segurança da informação devem ser usados para reduzir a probabilidade ou o impacto de incidentes futuros
    - Recolha de evidências – a organização deve definir e aplicar procedimentos para a identificação, colheita, aquisição e preservação das informações, as quais podem servir como evidências

# Controlos da norma ISO 27002

---

- Gestão da continuidade do negócio
  - Objetivo – continuidade da segurança da informação
    - A continuidade da segurança da informação deve ser contemplada nos sistemas de gestão da continuidade de negócio da organização
  - Controlos
    - Planeamento da continuidade da segurança da informação – a organização deve determinar seus requisitos para a segurança da informação e a continuidade da gestão da segurança da informação em situações adversas, por exemplo, durante uma crise ou desastre
    - Implementação da continuidade da segurança da informação – a organização deve estabelecer, documentar, implementar e manter processos, procedimentos e controlos para assegurar o nível requerido de continuidade para a segurança da informação, durante uma situação adversa

# Controlos da norma ISO 27002

---

- Gestão da continuidade do negócio
  - Objetivo – continuidade da segurança da informação
    - A continuidade da segurança da informação deve ser contemplada nos sistemas de gestão da continuidade de negócio da organização
  - Controlos
    - Verificação, revisão e avaliação da continuidade da segurança da informação – a organização deve verificar os controlos de continuidade da segurança da informação, estabelecidos e implementados, em intervalos regulares, para garantir que eles são válidos e eficazes em situações adversas

# Controlos da norma ISO 27002

---

- Gestão da continuidade do negócio
  - Objetivo – redundâncias
    - Assegurar a disponibilidade dos recursos de processamento da informação
  - Controlos
    - Disponibilidade dos recursos de processamento da informação - os recursos de processamento da informação devem ser implementados com redundância suficiente para atender aos requisitos de disponibilidade

# Controlos da norma ISO 27002

---

- Conformidade
  - Objetivo – conformidade com requisitos legais e contratuais
    - Evitar violação de quaisquer obrigações legais, estatutárias, regulamentares ou contratuais relacionadas com a segurança da informação e de quaisquer requisitos de segurança
  - Controlos
    - Identificação da legislação aplicável e de requisitos contratuais – todos os requisitos legais, regulamentares e contratuais relevantes, e a abordagem da organização para atender a tais requisitos, devem ser explicitamente identificados, documentados e mantidos atualizados para cada sistema de informação da organização
    - Direitos de propriedade intelectual – procedimentos apropriados devem ser implementados para garantir a conformidade com os requisitos legais, regulamentares e contratuais relacionados com os direitos de propriedade intelectual, e sobre o uso de produtos de software proprietário

# Controlos da norma ISO 27002

---

- Conformidade
  - Objetivo – conformidade com requisitos legais e contratuais
    - Evitar violação de quaisquer obrigações legais, estatutárias, regulamentares ou contratuais relacionadas com a segurança da informação e de quaisquer requisitos de segurança
  - Controlos
    - Proteção de registos – registos devem ser protegidos contra perda, destruição, falsificação, acesso não autorizado e libertação não autorizada, de acordo com os requisitos regulamentares, estatutários, contratuais e do negócio
    - Proteção e privacidade de informações de identificação de pessoal – a privacidade e proteção das informações de identificação pessoal devem ser asseguradas conforme requerido por legislação e regulamentação pertinente, quando aplicável
    - Regulamentação de controlos de criptografia - controlos de criptografia devem ser usados em conformidade com todas as leis, acordos, legislação e regulamentações pertinentes

# Controlos da norma ISO 27002

---

- Conformidade
  - Objetivo – revisão da segurança da informação
    - Garantir que a segurança da informação está implementada e operada de acordo com as políticas e procedimentos da organização
  - Controlos
    - Análise crítica independente da segurança da informação - o enfoque da organização para gerir a segurança da informação e a sua implementação (por exemplo, controlos, objetivo dos controlos, políticas, processos e procedimentos para a segurança da informação) deve ser analisado criticamente, de forma independente, em intervalos planeados, ou quando ocorrerem mudanças significativas
    - Conformidade com as políticas e normas de segurança da informação - os gestores devem analisar criticamente, em intervalos regulares, a conformidade dos procedimentos e do processamento da informação, dentro das suas áreas de responsabilidade, com as normas e políticas de segurança e quaisquer outros requisitos de segurança da informação

# Controlos da norma ISO 27002

---

- Conformidade
  - Objetivo – revisão da segurança da informação
    - Garantir que a segurança da informação está implementada e operada de acordo com as políticas e procedimentos da organização
  - Controlos
    - Análise crítica da conformidade técnica - os sistemas de informação devem ser analisados criticamente, em intervalos regulares, para verificar a conformidade com as normas e políticas de segurança da informação da organização